ĐẠI HỌC ĐÀ NẴNG
TRƯỜNG ĐẠI HỌC BÁCH KHOA
Khoa: Công nghệ thông tin

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc Lập - Tự Do - Hạnh Phúc

CHƯƠNG TRÌNH GIÁO DỤC ĐẠI HỌC

Trình độ đào tạo: Chuyên sâu đặc thù
Ngành/Chuyên ngành: Công nghệ thông tin (Đặc thù – Hợp tác doanh nghiệp) Mã số: 7480201

ĐỀ CƯƠNG CHI TIẾT HỌC PHẦN

Tên học phần: Kiểm thử Xâm nhập
Tên tiếng Anh: Penetration Testing

1. Mã học phần:	
2. Ký hiệu học phần:	
3. Số tín chỉ:	02 TC
4. Phân bố thời gian:	
- Lý thuyết:	20 tiết
- Bài tập/Thảo luận:	10 tiết
- Thực hành/Thí nghiệm:	0 tiết
- Tự học:	60 tiết
5. Các giảng viên phụ trách học phần	
- Giảng viên phụ trách chính:	ThS. Nguyễn Thế Xuân Ly
- Danh sách giảng viên cùng giảng dạy:	PGS. TS. Nguyễn Tấn Khôi
- Bộ môn/ Khoa phụ trách giảng dạy:	Mạng máy tính & Truyền thông/ Công nghệ thông tin
6. Điều kiện tham gia học phần:	
- Học phần tiên quyết:	Không có
- Học phần học trước:	Không có
- Học phần song hành:	An toàn thông tin mạng
7. Loại học phần:	☐ Bắt buộc ☐ Tự chọn bắt buộc ☒ Tự chọn tự do
8. Thuộc khối kiến thức	☐ Toán và KHTN ☐ Kiến thức chung ☐ Kiến thức Cơ sở ngành ☒ Kiến thức Chuyên ngành ☐ Kiến thức bổ trợ ☐ Đồ án/ Thực tập/Tốt nghiệp

9. Mô tả tóm tắt học phần:

Học phần nhằm cung cấp cho sinh viên khái niệm về kiểm thử xâm nhập, xác định các lỗ hổng trong hệ thống, kiểm tra tính hiệu quả của các chính sách bảo mật, kiểm tra các thành phần tiếp xúc công khai như tường lửa, bộ định tuyến và hệ thống phân giải tên miền. Rèn luyện cho sinh viên khả năng tìm ra các tuyến dễ bị tổn thất nhất mà qua đó một cuộc tấn công có thể được thực hiện và tìm kiếm các lỗ hổng có thể dẫn đến hành vi trộm cắp dữ liệu nhạy cảm.

10. Chuẩn đầu ra của học phần:

Sau khi kết thúc học phần sinh viên có khả năng:

STT	Chuẩn đầu ra học phần (CLO)	Kiến thức	Kỹ năng	Thái độ	Chỉ báo PI (thuộc PLO)
1	Trình bày được các khái niệm và kỹ thuật kiểm thử xâm nhập	Hiểu (Understand)			2.1.2 2.1.5 2.1.6
2	Áp dụng được các kiến thức kiểm thử xâm nhập xây dựng và triển khai được các kịch bản kiểm thử xâm nhập thực tế.	Vận dụng (Apply)	Vận dụng		2.2.1
3	Đánh giá được hiệu quả của các giải pháp kiểm thử xâm nhập.		Đánh giá (Evaluate)		6.2.1
4	Vận dụng được các kỹ năng giải quyết vấn đề, giao tiếp, làm việc nhóm, tra cứu, trích dẫn tài liệu, báo cáo & phát triển hệ thống.		Vận dụng (Apply)	Chịu trách nhiệm cá nhân và trách nhiệm đối với nhóm	5.1.3 5.2.1 5.2.2 5.3.1

11. Mối liên hệ của CĐR học phần (CLOs) đến CĐR Chương trình đào tạo (PLOs):

PLO	PLO 1	PLO 2	PLO 3	PLO 4	PLO 5	PLO 6	PLO7
Đóng góp của học phần		TU			U	T	
CLO 1		X					
CLO 2		X					
CLO 3						X	
CLO 4					X		

12. Nhiệm vụ của học viên:

Sinh viên phải thực hiện các nhiệm vụ sau đây:
- Tham gia ít nhất 80% số tiết học của lớp học phần;
- Tham gia các hoạt động làm việc nhóm theo qui định của lớp học phần;
- Tự tìm hiểu các vấn đề do giảng viên giao để thực hiện ngoài giờ học trên lớp;
- Hoàn thành tất cả bài đánh giá của học phần.

13. Đánh giá học phần:

Thành phần đánh giá	**Bài đánh giá**	**Phương pháp đánh giá**	**Tiêu chí**	**Trọng số cấu phần (%)**	**Trọng số thành phần (%)**	**CĐR học phần**

A1. Đánh giá quá trình	A1.1 Chuyên cần và thực hiện bài tập ngắn trên lớp	P1.1 Điểm danh (ngẫu nhiên 3 lần), làm bài tập trên giấy	R1.1 Trừ điểm theo số lần vắng, đánh giá theo quy định chung	W1.1 40%	W1 20%	CLO 4
	A1.2 Bài tập ở nhà cho cá nhân/nhóm	P1.2 Báo cáo bài tập cá nhân/ nhóm	R1.2: - Làm bài tập đầy đủ - Kết quả xây dựng hệ thống mạng/ lập trình chạy đúng và đánh giá được hiệu quả.	W1.2 60%		CLO 1, 2, 3, 4
A2.Đánh giá giữa kỳ	A2.1 Bài kiểm tra giữa kỳ	P2.1 Trắc nghiệm	R2.1 Đúng theo đáp án	W2.1 100%	W2 20%	CLO 1, 2, 3
A3. Đánh giá cuối kỳ	A3.1 Thi cuối kỳ	P3.1 Trắc nghiệm	R3.1 Đúng theo đáp án	W3.1 100%	W3 60%	CLO 1, 2, 3

14. Kế hoạch giảng dạy và học

Tuần/ Buổi	Nội dung chi tiết	Hoạt động dạy và học	Bài đánh giá	CĐR học phần
1.	**Giới thiệu học phần.** **Chương 1. Giới thiệu chung** **1.1. Khái niệm và tầm quan trọng** **1.2. Phân loại** **Kiểm thử xâm nhập từ bên ngoài** **Kiểm thử xâm nhập từ bên trong**	**Dạy:** - Giảng viên giới thiệu đến sinh viên mục tiêu môn học; vị trí và vai trò của môn học trong chương trình đào tạo của ngành; chuẩn đầu ra môn học, các hình thức kiểm tra đánh giá và trọng số của các bài đánh giá, nội dung học phần theo chương. - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Trả lời các câu hỏi của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm. - Thảo luận: Chia nhóm thảo luận về các đặc trưng mạng máy tính **Học ở nhà:**	A1.1	CLO 1

		- Ôn lại lý thuyết		
2	**Chương 2. Kiểm thử xâm nhập mạng (Network Penetration Testing)** **2.1. Ôn tập mô hình OSI, mô hình TCP/IP** **2.2. Tường lửa**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà	A1.1 A1.2	CLO 1, 2
3	**Chương 2. Kiểm thử xâm nhập mạng (Network Penetration Testing)** **2.3. Kiểm thử xâm nhập mạng với công cụ NMap**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà	A1.1 A1.2	CLO 1, 2
4	**Chương 2. Kiểm thử xâm nhập mạng (Network Penetration Testing)** **2.4. Khai thác lỗ hổng với Metasploit Framework**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra.	A1.1 A1.2	CLO 1, 2

		- Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà		
5	**Chương 2. Kiểm thử xâm nhập mạng (Network Penetration Testing)** **2.5. Wireshark và tấn công nghe lén ARP Poisoning** **2.6. Các công cụ khác**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi cho sinh viên suy nghĩ và trả lời. - Hướng dẫn sinh viên làm bài tập. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. - Làm bài tập. - Trình bày bài tập nhóm. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà.	A1.1 A1.2	CLO 1, 2, 4
6	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.1. Ứng dụng Web hoạt động như thế nào** **3.1.1. Nguyên lý hoạt động** **3.1.2. Header của gói tin HTTP/HTTPS** **3.1.3. Request body** **3.1.4. SESSION và COOKIE**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà	A1.1 A1.2	CLO 1, 2
7	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)**	Dạy: - Hướng dẫn sinh viên làm bài tập.	A1.1 A1.2	CLO 1, 2, 3, 4

	3.1.4. Công cụ BurpSuit, CUrl, WGet và script để tương tác với ứng dụng web	- Trả lời thắc mắc của sinh viên. **Học ở lớp:** - Thảo luận làm bài tập nhóm. **Học ở nhà:** - Hoàn chỉnh bài tập nhóm.		
8	Kiểm tra giữa kỳ		A2.1	CLO 1, 2, 3
9	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.2. Các chuẩn kiểm thử xâm nhập web và chuẩn OWASP** **3.2.1. Giới thiệu các chuẩn kiểm thử xâm nhập** **3.2.2. Chuẩn kiểm thử xâm nhập OWASP** **3.3. Thu thập thông tin (Information Gathering)** **3.3.1. Sự cần thiết của bước thu thập thông tin**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi cho sinh viên suy nghĩ và trả lời. - Hướng dẫn sinh viên làm bài tập. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. - Làm bài tập. - Trình bày bài tập nhóm. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà.	A1.1 A1.2	CLO 1, 2, 4
10	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.3.2. Các công cụ thu thập thông tin** **3.3.3. Thu thập thông tin với Google Hacking**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi cho sinh viên suy nghĩ và trả lời. - Hướng dẫn sinh viên làm bài tập. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. - Làm bài tập. **Học ở nhà:** - Ôn lại lý thuyết.	A1.1 A1.2	CLO 1, 2

		- Làm bài tập về nhà.		
11	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.4. Các kịch bản tấn công phổ biến** **3.4.1. Tấn công Cross-site Scripting**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà	A1.1 A1.2	CLO 1, 2
12	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.4.2. Tấn công SQL Injection và SQLMap**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà	A1.1 A1.2	CLO 1, 2
13	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.4.3. Tấn công File Upload**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra.	A1.1 A1.2	CLO 1, 2

		- Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà		
14	**Chương 3. Kiểm thử xâm nhập ứng dụng web (Web Application Penetration Testing)** **3.4.4. Tấn công Cross Site Request Forgery** **3.4.5. Password Cracking**	Dạy: - Giảng bài kết hợp trình chiếu slide bài giảng. - Đặt câu hỏi/ bài tập cho sinh viên suy nghĩ và trả lời. **Học ở lớp:** - Nghe giảng. - Suy nghĩ, thảo luận và trả lời các câu hỏi/ bài tập của giảng viên đưa ra. - Đặt câu hỏi các vấn đề quan tâm liên quan đến nội dung bài học. **Học ở nhà:** - Ôn lại lý thuyết. - Làm bài tập về nhà	A1.1 A1.2	CLO 1, 2
15	**Chương 4. Kiểm thử xâm nhập ứng dụng** **4.1. Mô hình phổ biến của ứng dụng** **4.2. Phương pháp dịch ngược và phân tích chương trình (Reversing Engineering)**	Dạy: - Hướng dẫn sinh viên làm bài tập. - Trả lời thắc mắc của sinh viên. **Học ở lớp:** - Thảo luận làm bài tập nhóm. **Học ở nhà:** - Hoàn chỉnh bài tập nhóm.	A1.1 A1.2, A1.4	CLO 1, 2, 3
16	**Chương 5. Giải pháp giám sát dựa vào các hình thức tấn công ứng dụng web (Tham khảo)**	Dạy: - Hướng dẫn và đánh giá sinh viên trình bày bài tập nhóm. - Trả lời thắc mắc của sinh viên. **Học ở lớp:** - Các thành viên của nhóm trình bày báo cáo bài tập nhóm. - Các nhóm thảo luận và nhận xét kết quả mỗi nhóm.	A1.1, A1.3	CLO 1, 2, 3, 4

		- Trả lời các câu hỏi của giảng viên và sinh viên nhóm khác. **Học ở nhà:** - Hoàn chỉnh bài tập nhóm.		
17	Thi cuối kỳ		A3.1	CLO 1, 2, 3

15. Tài liệu học tập:

15.1 Sách, bài giảng, giáo trình chính:

11 [1] Georgia Weidman, *Penetration Testing: A Hands-On Introduction to Hacking*, 1st Edition, William Pollock, 2014.

15.2 Sách, tài liệu tham khảo:

[1] Jon Erickson, *Hacking: The Art of Exploitation*, 2nd Edition, Addison Wesley, 2010.

16. Đạo đức khoa học:

- Sinh viên phải tôn trọng giảng viên và sinh viên/học viên/nghiên cứu sinh khác.
- Sinh viên phải thực hiện quy định liêm chính học thuật của Nhà trường.
- Sinh viên phải chấp hành các quy định, nội quy của Nhà trường.

17. Ngày phê duyệt: Tháng …/20…

18. Cấp phê duyệt:

Trưởng khoa	**Phụ trách CTĐT**	**Giảng viên biên soạn**
PGS.TS. Nguyễn Tấn Khôi	TS. Đặng Hoài Phương	ThS. Nguyễn Thế Xuân Ly